

PSI Projekt

Sprawozdanie wstępne

Zespół 34

Miłosz Andryszczuk - Lider

Aleksander Paliwoda

Maksymilian Zieliński

Wstęp

Celem projektu jest zaprojektowanie oraz implementacja w Pythonie szyfrowanego protokołu komunikacyjnego opartego na protokole TCP w architekturze klient-serwer. Protokół realizuje dynamiczną wymianę kluczy metodą Diffiego-Hellmana w pierwszych dwóch wiadomościach nieszyfrowanych (ClientHello i ServerHello). Każda następna wiadomość szyfrowana jest symetrycznie uzgodnionym kluczem. Komunikacja może zostać zakończona przez każdą ze stron poprzez wiadomość EndSession. Protokół zawiera mechanizm integralności i autentyczności "encrypt-then-mac" (wariant W1).

Struktura wiadomości

Każda wiadomość składa się ze stałego nagłówka i zmiennego pola danych (**Payload**).

Format Nagłówka (5 bajtów)

<i>Pole</i>	<i>Rozmiar</i>	<i>Typ danych</i>	<i>Opis</i>
Type	1B	char	Identyfikator typu wiadomości.
Length	4B	unsigned int	Długość pola Payload w bajtach.

Pole **Type** w nagłówku oraz pole **Payload** różnią się w zależności od typu wiadomości.

Zdefiniowane typy wiadomości i struktura Payload

<i>Nazwa</i>	<i>Typ (Hex)</i>	<i>Struktura Payload</i>	<i>Opis</i>
ClientHello	0x01	p (4B) g (4B) A (4B)	Klient przesyła parametry grupy p i g oraz swój klucz publiczny A .
ServerHello	0x02	B (4B)	Serwer odsyła swój klucz publiczny B .
SecureMessage	0x03	Ciphertext MAC (32B)	Zaszyfrowana treść wiadomości oraz tag uwierzytelniający.

Struktura danych szyfrowanych

Wewnętrzny typ (Data i EndSession) ukryty jest wewnątrz szyfrogramu. Przed zaszyfrowaniem, do każdej wiadomości typu **SecureMessage** dodawany jest 1-bajtowy prefix (flaga).

Typ Wewnętrzny	Wartość Flagi	Opis
Data	0x01	Tekst wiadomości od użytkownika.
EndSession	0x02	Żądanie zakończenia sesji.

Wykorzystywane algorytmy

1. Wymiana kluczy

W celu uzgodnienia wspólnego sekretu zostanie wykorzystany algorytm Diffiego-Hellmana, który przebiega następująco:

- Klient wybiera parametry grupy (p i g) oraz swój klucz prywatny. Na ich podstawie oblicza swój klucz publiczny (A).
- Klient wysyła p, g i A w wiadomości ClientHello.
- Serwer losuje swój klucz prywatny i oblicza klucz publiczny (B) za pomocą parametrów grupy.
- Serwer odsyła B w wiadomości ServerHello.
- Zarówno Klient jak i Serwer obliczają wspólny sekret.

Obliczony klucz zostanie dodatkowo przepuszczony przez funkcję skrótu w celu uzyskania ostatecznego 32-bajтового klucza sesji.

2. Szyfrowanie

W celu zapewnienia poufności przy jednoczesnym zachowaniu prostoty protokołu zostanie zastosowany symetryczny szyfr strumieniowy oparty na operacji XOR.

- Każdy bajt wiadomości jawnej zostanie poddany operacji logicznej XOR z odpowiadającym mu bajtem klucza sesji.
- W przypadku, gdy wiadomość jest dłuższa niż klucz, klucz zostanie wykorzystany w sposób cykliczny (zapętlony).

3. Integralność i Autentyczność

W celu zapewnienia integralności i autentyczności zostanie zaimplementowany mechanizm HMAC-SHA256 w układzie Encrypt-then-MAC.

- Nadawca szyfruje wiadomość jawną razem z flagą typu, uzyskując szyfrogram.
- Na podstawie uzyskanego szyfrogramu oraz klucza sesji nadawca oblicza skrót uwierzytelniający (Tag) przy użyciu funkcji HMAC z algorytmem SHA-256.
- Do odbiorcy wysyłana jest para: Szyfrogram + Tag.
- Odbiorca najpierw oddziela Tag od szyfrogramu i oblicza Tag dla otrzymanych danych.
- Dopiero jeśli obliczony Tag jest zgodny z tym odebrany, następuje proces deszyfrowania. W przeciwnym razie pakiet jest odrzucany.

Wszystkie wiadomości przesyłane po ustaleniu klucza mają w nagłówku jawnym ten sam typ (**SecureMessage**). Rozróżnienie między zwykłą wiadomością a żądaniem zakończenia sesji następuje dopiero po poprawnej weryfikacji HMAC i odszyfrowaniu danych przez odbiorcę, poprzez sprawdzenie flagi wewnętrznej.